

Handoff técnico y funcional

FAMEDIC–LeoV

Adecuación de plataforma y APIs para el MVP del asistente virtual

Dirigido a: Lalio | Versión 1.0 | 12 de julio de 2026

Convención de nombres: en este paquete, “LeoV” identifica al asistente virtual de FAMEDIC. “Leo” se reserva para referirse al destinatario humano cuando corresponda.

1. Propósito

Alinear la plataforma FAMEDIC, la API Akubica y la futura integración del proveedor con las definiciones funcionales, conversacionales, operativas y de seguridad aprobadas para LeoV. Este documento convierte los hallazgos detectados en decisiones, requerimientos implementables, preguntas técnicas y criterios de aceptación.

2. Resultado esperado

- Un MVP de LeoV centrado principalmente en usuarios finales atendidos por WhatsApp.
- Conocimiento estable proveniente de documentos vigentes y datos dinámicos obtenidos por API.
- Autenticación y verificaciones sensibles mediante OTP por SMS.
- Búsqueda y cotización confiable de estudios, incluyendo variantes y cantidades de elementos.
- Acciones transaccionales controladas, con confirmación previa y trazabilidad.
- Entrega segura de resultados y facturas, sin adjuntar documentos sensibles directamente en WhatsApp.
- Un contrato API completo, consistente entre OpenAPI, Postman y guías.

3. Decisiones funcionales aprobadas

ID	Tema	Decisión
DEC-001	Alias	El asistente virtual se denominará LeoV en documentos técnicos e internos.
DEC-002	Público principal	LeoV atenderá prioritariamente a usuarios finales. Empresas y médicos recibirán información general solo cuando lo soliciten expresamente.
DEC-003	Canal	WhatsApp es el canal principal; las respuestas deben ser breves, móviles, sin tablas anchas y con una pregunta principal por mensaje.
DEC-004	Fuentes	API de producción para datos dinámicos; base vigente para conocimiento estable; contenido histórico nunca como respuesta vigente.
DEC-005	Farmacia	Nueva compra y catálogo suspendidos. Pedidos históricos consultables. Mantener respuesta 503 para funciones desactivadas.
DEC-006	Cancelaciones	LeoV no cancela pedidos. La solicitud se escala; mantener endpoint desactivado mientras no exista proceso aprobado.
DEC-007	Pago	LeoV no procesa ni tokeniza pagos. Puede preparar el carrito y, si se aprueba técnicamente, generar una liga para completar el pago en FAMEDIC.
DEC-008	Resultados	No interpretar resultados ni enviar PDF como adjunto. Requieren sesión, OTP SMS y liga

		temporal segura.
DEC-009	Facturas	Solicitud dentro del mismo mes calendario; acceso y descarga mediante control reforzado y liga segura.
DEC-010	Estudios ambiguos	No seleccionar automáticamente variantes. Comparar coincidencia exacta, cantidad de elementos, alias y componentes; mostrar máximo tres opciones.

4. Alcance recomendado del MVP

4.1 Capacidades a habilitar

- Información general de FAMEDIC, Plan Básico, relación con ODESSA y servicios vigentes.
- Registro y acceso de LeoV mediante OTP por SMS.
- Consulta de marcas, categorías, estudios, detalle, preparación, cita, precios, sucursales y disponibilidad.
- Resolución de ambigüedad de estudios y variantes.
- Carrito: consultar, agregar, retirar, vaciar y consultar totales, siempre con confirmación en modificaciones.
- Pacientes/contactos y direcciones: consulta y CRUD con confirmación.
- Preparación de checkout y generación de liga de pago, condicionada a seguridad, expiración y confirmación.
- Pedidos: listado, estado, productos y pedidos históricos de Farmacia.
- Resultados y facturas: consulta de disponibilidad y generación de acceso seguro.
- Perfiles fiscales y solicitud de factura.
- Escalamiento humano con transferencia de contexto mínimo.

4.2 Fuera del MVP o bloqueado

- Cobro o captura de tarjeta en WhatsApp.
- Interpretación clínica, diagnóstico o recomendación de medicamentos.
- Cancelaciones y reembolsos automáticos.
- Farmacia nueva.
- Fusión automática de cuentas.
- Cotizaciones o contratación B2B.
- Citas autónomas hasta validar slots, sucursal, confirmación y proceso operativo.
- Descarga directa Bearer-native hacia el usuario mientras no exista liga segura.

5. Hallazgos sobre la API actual

ID	Prioridad	Módulo	Hallazgo	Acción requerida
HAL-001	P0	Autenticación	La API documentada usa OTP por correo; el MVP aprobado requiere OTP por SMS.	Adaptar registro, login y verificaciones sensibles a SMS, con correo como respaldo opcional.
HAL-002	P0	Resultados/facturas	La API devuelve PDF binario con Bearer; no existe liga temporal ni segundo factor.	Crear endpoint de liga segura temporal, ligado a usuario y recurso.
HAL-003	P0	Contrato API	OpenAPI, Postman y guías no presentan la misma cobertura.	Entregar OpenAPI consolidado con todas las operaciones disponibles.

HAL-004	P0	Autorización	No está documentada la validación de titularidad por recurso.	Documentar y probar autorización para pedidos, resultados, facturas, contactos y direcciones.
HAL-005	P0	OTP	No están documentados TTL, intentos, reenvíos, bloqueo ni anti-enumeración.	Implementar y documentar política completa.
HAL-006	P1	Catálogo público	Documentos funcionales permiten consulta pública, pero Postman envía Bearer.	Confirmar y definir si catálogo/precios son públicos.
HAL-007	P1	Estudios	No se demuestra soporte para alias, elementos, componentes ni equivalencias.	Enriquecer búsqueda y detalle.
HAL-008	P1	Citas	POST de cita no incluye store_id ni slots; no se sabe si confirma o solicita.	Rediseñar o aclarar contrato y flujo.
HAL-009	P1	Idempotencia	No está documentada en operaciones de escritura.	Agregar Idempotency-Key o mecanismo equivalente.
HAL-010	P1	Escalamiento	No existe endpoint documentado para transferir contexto a atención.	Crear integración o definir mecanismo operativo.
HAL-011	P1	Errores	Códigos y políticas de reintento están incompletos.	Estandarizar errores y clasificación retryable/no retryable.
HAL-012	P2	Postman	Environment contiene variable password aunque el flujo no la usa.	Eliminar variable y asegurar secretos.

6. Requerimientos obligatorios P0

REQ-AUT-001 — OTP SMS para registro y login

Enviar código por SMS; correo opcional como respaldo. La API no debe requerir contraseña para el canal LeoV.

REQ-AUT-002 — Política OTP

TTL recomendado 5 minutos; 5 intentos; reenvío después de 60 segundos; máximo 3 reenvíos en 15 minutos; bloqueo temporal; uso único; asociación a intención.

REQ-AUT-003 — Protección anti-enumeración

Las respuestas de solicitud de código no deben revelar si una cuenta existe.

REQ-SEC-001 — Titularidad del recurso

Cada endpoint debe comprobar que el token puede acceder al recurso solicitado.

REQ-SEC-002 — Ligas seguras

Generar ligas de resultados y facturas con TTL de 60 minutos, revocables, sin datos sensibles en URL y con registro de apertura.

REQ-API-001 — OpenAPI completo

La especificación debe cubrir todas las rutas liberadas y coincidir con Postman y guías.

REQ-API-002 — Idempotencia

Operaciones CREATE/UPDATE/DELETE críticas deben aceptar una clave idempotente.

REQ-OPS-001 — Escalamiento

Definir endpoint o mecanismo para enviar contexto mínimo a atención humana y confirmar que fue recibido.

7. Requerimientos funcionales P1

- Catálogo: devolver nombre oficial, alias, element_count, components, preparación, cita, marca, precio, cobertura, disponibilidad y vigencia.
- Búsqueda: aceptar errores ortográficos y devolver score/tipo de coincidencia sin declarar equivalencias no confirmadas.
- Citas: exponer sucursal, slots reales, zona horaria, estado solicitado/confirmado, reglas de reprogramación y cancelación.
- Payment link: definir expiración, un solo uso, relación con carrito, invalidez después del pago y qué ocurre si cambia el carrito.
- Errores: incluir code estable, message segura, details validables, correlation_id y retryable.
- Auditoría: registrar usuario, canal, intención, endpoint, resultado, identificador, error y escalamiento sin guardar secretos.
- Perfil y planes: confirmar endpoints o declarar fuera de MVP para perfil principal, familiares, plan activo y beneficios.

8. Preguntas de decisión para Lalio

1. ¿Los endpoints de catálogo funcionan sin Bearer token? ¿Cuál será la política definitiva?
2. ¿Qué proveedor SMS utiliza FAMEDIC y puede reutilizarse para la API Akubica?
3. ¿Cuál será la política final de OTP y token de sesión?
4. ¿Cómo se evita que un usuario consulte un order_id, contact_id o invoice_id ajeno?
5. ¿Puede implementarse una liga segura temporal sin exponer Bearer token al navegador o WhatsApp?
6. ¿El payment link es de un solo uso? ¿Qué TTL admite y cómo se invalida?
7. ¿La cita creada queda confirmada o solo solicitada? ¿Cómo se selecciona sucursal y slot?
8. ¿Qué campos devuelve actualmente el catálogo para componentes y variantes?
9. ¿Qué mecanismo se usará para escalamiento humano y recepción de contexto?
10. ¿Cuál será la fuente técnica oficial tras la actualización: OpenAPI consolidado?

9. Entregables solicitados a Lalio

- OpenAPI 3.x consolidado y versionado.
- Colección Postman y environment sanitizado.
- Matriz endpoint-capacidad-estado de liberación.
- Política de OTP, tokens y sesiones.
- Catálogo de errores con ejemplos.
- Evidencia de autorización por recurso.

- Evidencia de idempotencia.
- Pruebas de ligas seguras de resultados y facturas.
- Pruebas de búsqueda de variantes de estudios.
- Pruebas de payment link y citas.
- Mecanismo documentado de escalamiento.
- Reporte de resultados del checklist de aceptación.

10. Orden recomendado de implementación

11. Confirmar alcance cerrado del MVP y decisiones de autenticación.
12. Implementar OTP por SMS y política de sesión.
13. Completar OpenAPI y estandarizar errores.
14. Fortalecer autorización, idempotencia y auditoría.
15. Implementar ligas seguras para documentos.
16. Enriquecer catálogo y búsqueda de variantes.
17. Definir y ajustar citas, payment link y escalamiento.
18. Ejecutar checklist de seguridad y pruebas end-to-end.
19. Entregar contratos definitivos al proveedor externo.

11. Criterio de liberación

Una capacidad solo podrá declararse “Habilitada en producción” cuando exista contrato API definitivo, controles de seguridad, pruebas satisfactorias, evidencia, manejo de errores, trazabilidad y aprobación funcional. La existencia de un endpoint no equivale a autorización de uso por LeoV.